

МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА — Российский технологический университет»

РТУ МИРЭА

Институт кибербезопасности и цифровых технологий
Кафедра КБ-4 «Интеллектуальные системы информационной безопасности»

Практическое задание №9

по дисциплине: «Методы сбора и обработки данных из открытых источников»

тема: «OSINT-мониторинг изменений цифровой экспозиции»

Выполнил: студент группы ББМО-01-25

Мухаметшин Александр Ринатович

Проверил: _____

Москва, 2026

1. Паспорт мониторинга

Форма 1. Паспорт мониторинга

Поле	Содержание
Объект мониторинга	Яндекс (Yandex) — SaaS-технологическая платформа / экосистема
Отрасль / тип объекта	Технологическая платформа, SaaS-сервис, интернет-экосистема
Цель мониторинга	Спроектировать учебную модель регулярного OSINT-мониторинга изменений цифровой экспозиции Яндекса: зафиксировать базовую линию, разработать каталог индикаторов, собрать журнал наблюдений, выделить значимые сигналы, оформить карточки предупреждений, сформулировать защитные рекомендации
Период наблюдения	Базовая линия — май 2026 г. (агрегация данных практик 1–8); мониторинг — отслеживание изменений от базовой линии
Исходные материалы	Данные практик 1–8: WHOIS, DNS, TLS-сертификаты (crt.sh), ASN-реестры (bgp.he.net), OAuth-спец, HTTP-заголовки (CSP, NEL), публичная документация, GitHub OSS (65K+ звёзд), вакансии (hh.ru), архивные копии (web.archive.org), пресс-релизы, технологические блоги
Границы мониторинга	Включено: домены, сервисные контуры, документация, вакансии, help-центры, технологические публикации, OSS-репозитории, архивные следы, HTTP-заголовки, TLS-сертификаты, события. / Не включено: активная проверка инфраструктуры, непубличные API, персональные данные, мобильные приложения.
Исходные гипотезы мониторинга	Г1: Вакансии и технологические публикации содержат наиболее динамичную часть цифровой экспозиции — изменения появляются ежеквартально. — Г2: OSS-документация и developer-контур систематически расширяются, что повышает наблюдаемость внутренней архитектуры. — Г3: Исторические архивные следы (web.archive.org) содержат изменения, которые

	формально не являются текущими, но влияют на общую картину экспозиции.
--	--

2. Границы наблюдения и классы источников

Форма 2. Карта классов источников наблюдения

Класс источника	Примеры URL / инструментов	Что отслеживаем	Частота проверки	Доверие
Официальный сайт	ya.ru, yandex.ru	Главная страница, навигация, скрытые разделы	Еженедельно	Высокое
Доменная инфраструктура	whois.domaintools.com, dnschecker.org, crt.sh	Новые домены, DNS-записи, TLS-сертификаты	Ежемесячно	Высокое
Документация и help-центр	tech.yandex.ru, cloud.yandex.net/docs, developer.yandex.ru	Новые страницы, changelog, обновления документации	Ежемесячно	Высокое
Вакансии и карьера	hh.ru/employer/yandex, tech.yandex.ru/career	Новые роли, изменение требований, новые подразделения	Еженедельно	Среднее
Официальные публикации	tech.yandex.ru, press.yandex.ru, habr.com/ru/company/yandex	Новые статьи, презентации, технические блоги	Ежемесячно	Среднее
OSS-репозитории	github.com/yandex, ydb.tech, diplodoc.tech, catboost.ai	Новые репозитории, обновления docs, изменения CI/CD	Ежемесячно	Высокое
Веб-архив	web.archive.org	Новые/удалённые страницы, изменения контента	По запросу	Среднее
Почтовые индикаторы	DNS TXT (SPF, DKIM, DMARC), mx.yandex.ru	Изменения SPF-политик, новые DKIM-записи	Ежемесячно	Высокое
Пресс-релизы и события	press.yandex.ru, infraevents.yandex.ru	Новые анонсы, конференции, выделения	По запросу	Среднее
Сервисные заголовки	curl / DevTools (CSP, NEL, x-yandex-req-id)	Новые заголовки, изменения	По запросу	Среднее

		ПОЛИТИК		
--	--	---------	--	--

3. Базовая линия цифровой экспозиции

Форма 3. Базовая линия цифровой экспозиции (на основе практик 1–8)

Элемент	Состояние на момент базовой линии	Источник практики
Основной домен	ya.ru (HTTP 302 → yandex.ru); yandex.ru — исторический	Практика 1 (WHOIS)
Доменные контуры	6+ функциональных контуров: поиск, облако (AS200350), OAuth, CDN (yastatic.net), OSS-продукты, медиа (dzen.ru)	Практика 1, 3
Облачная платформа	cloud.yandex.net + cloud.yandex.ru, ASN AS200350, CloudAPI gRPC/REST	Практика 1, 4
OAuth-контур	oauth.yandex.com — OAuth 2.0 PKCE S256 (RFC 8252), единый для всех продуктов	Практика 2, 5
OSS-экосистема	github.com/yandex (65K+ звёзд); ydb.tech, ytsaurus.tech, diplodoc.tech, catboost.ai — все с документацией	Практика 4, 5, 6
Технологический блог	tech.yandex.ru — 12+ категорий контента	Практика 2, 5
Почтовая инфраструктура	mx.yandex.ru (pri 10); SPF (redirect); DKIM; mail.yandex.ru	Практика 1, 3
CDN	yastatic.net (37.9.64.225) — единая CDN с CSP-интеграцией	Практика 1, 2
Вакансии	hh.ru/employer/yandex — 600+ developer, 150+ ML позиции	Практика 2, 4
Исторические следы	dzen.yandex.net (web.archive.org); career.yandex.ru (HTTP 404); устаревшие OAuth-эндпоинты	Практика 3, 6
Публикации и события	infraevents.yandex.ru, press.yandex.ru, Habr, Яндекс.Субботник	Практика 4, 6, 7
Внешние интеграции	google-site-verification (TXT), facebook-domain-verification	Практика 3, 5

	(TXT)	
Сервисные заголовки	x-yandex-req-id (HTTP); NEL-эндпоинты dr.yandex.net, dr2.yandex.net	Практика 2, 5
SSL/Сертификаты	GlobalSign — основной CA; множество сертификатов через crt.sh	Практика 1, 3

3. Фильтрация: сигнал vs шум

Форма 7. Фильтрация: сигнал vs шум

Наблюдения, отнесённые к информационному шуму

Критерий шума	Наблюдения, отнесённые к шуму	Обоснование
Дублирующиеся публикации	OBS-15 (press.yandex.ru + Habr — одни и те же анонсы)	Публикация дублируется на разных площадках; не добавляет новой информации об экспозиции
Маркетинговые сообщения	OBS-12 (Яндекс.Субботник — ивент, не меняет цифровую экспозицию)	Событийный контент ≠ изменение инфраструктуры; относится к публичной коммуникации
Общие формулировки	OBS-13 (google-site-verification — стандартная интеграция, без изменений)	Стандартная практика для всех сайтов; не указывает на специфические изменения экспозиции
Материалы без отношения к экспозиции	OBS-10 (career.yandex.ru HTTP 404 — переезд, не новое изменение)	Переезд на hh.ru — стандартная практика HR; не меняет цифровой контур
Устаревшие следы без текущего значения	OBS-09 (dzen.yandex.net — исторический, более не актуален)	Отделён от Яндекса в 2022; шум для текущего контура

Наблюдения, отнесённые к значимым сигналам

Критерий сигнала	Наблюдения, отнесённые к сигналам	Обоснование
Связь с инфраструктурой	OBS-02 (ASN AS200350), OBS-06 (OSS-домены), OBS-14 (CDN)	Меняет карту цифрового контура; подтверждено DNS + WHOIS
Степень детализации	OBS-05 (65K+ звёзд), OBS-07 (600+ dev)	Высокая информативность для внешнего наблюдателя
Повторяемость	OBS-05, OBS-06, OBS-07	Паттерн воспроизводим;

	(характерно для технологических компаний)	типично для отрасли
Подтверждение несколькими источниками	OBS-05 (GitHub + tech.yandex.ru/career), OBS-06 (ydb.tech + ytsaurus.tech)	Независимое подтверждение повышает уровень уверенности
Потенциальная полезность для внешнего наблюдателя	OBS-05, OBS-06, OBS-07 (технологический стек, архитектура)	Повышает информированность о системе; значимый сигнал

4. Карточки предупреждений

Форма 9. Карточка предупреждения 1

Поле	Содержание
Название сигнала	SIG-1: Расширение OSS-экосистемы — избыточная детализация архитектуры
Описание	OSS-продукты Яндекса (ydb.tech, ytsaurus.tech, diplodoc.tech) функционируют как самостоятельные контуры с собственной документацией, что расширяет наблюдаемость внутренней архитектуры
Источник	github.com/yandex (65K+ звёзд); ydb.tech/docs/en/; ytsaurus.tech/docs/en/; diplodoc.tech
Что изменилось	Каждый OSS-продукт получил собственный .tech-домен с полной документацией — это увеличивает цифровую экспозицию за счёт детализированной открытой информации об архитектуре
Почему это важно	OSS-документация содержит: внутренние API-эндпоинты, примеры кода, CI/CD-паттерны, тестовые конфигурации. Для внешнего наблюдателя это наиболее информативный источник о внутренней структуре организации
Уровень уверенности	Высокий — подтверждён прямым доступом к documentation-ресурсам (HTTP 200, полный контент), github.com/yandex
Приоритет	Высокий — наиболее информативная экспозиция из всех наблюдаемых категорий
Возможное защитное действие	Аудит OSS-репозиторий; удаление примеров с внутренними API; pre-commit хуки для проверки на чувствительные паттерны
Ограничения вывода	OSS-продукты могут быть ориентированы на публичное использование; не все документы содержат конфиденциальную информацию

Форма 10. Карточка предупреждения 2

Поле	Содержание
Название сигнала	SIG-2: Кадровая экспозиция — технологический стек через вакансии
Описание	hh.ru/employer/yandex содержит 600+ developer и 150+ ML вакансий с детализацией технологического стека
Источник	hh.ru/employer/yandex; tech.yandex.ru/career
Что изменилось	Вакансии стабильно раскрывают конкретные технологии (C++, Python, Java, Kubernetes, ClickHouse, YDB), что позволяет восстановить актуальный и планируемый технологический ландшафт
Почему это важно	Вакансии — наиболее динамичная часть цифровой экспозиции. Детализация требований позволяет внешнему наблюдателю определить: используемые платформы, создаваемые команды, планируемые проекты. Это снижает стоимость подготовки целенаправленной атаки
Уровень уверенности	Средний — HR-данные подтверждены tech.yandex.ru/career; не проверялись активными методами
Приоритет	Высокий — высокодинамичный источник с высокой информативностью
Возможное защитное действие	Обобщение формулировок в вакансиях; исключение конкретных версий библиотек и кодовых названий проектов
Ограничения вывода	Вакансии ≠ текущая инфраструктура; требования могут опережать фактическое использование технологий

Форма 11. Карточка предупреждения 3

Поле	Содержание
Название сигнала	SIG-6: Исторические следы — цифровой шум из архивов
Описание	web.archive.org сохраняет исторические копии страниц Яндекса, которые повышают информированность внешнего наблюдателя об устаревшем сервисном контуре
Источник	web.archive.org; dzen.yandex.net (исторический); career.yandex.ru (HTTP 404)
Что изменилось	Исторические страницы сохраняются в архивах и могут быть использованы для

	реконструкции прошлых конфигураций безопасности, архитектуры сервисов и процессов
Почему это важно	Исторические данные могут включать: старые SPF/DKIM/DMARC записи, устаревшие OAuth-эндпоинты, незакрытые внутренние URL, имена сотрудников. Особенно опасно, когда исторические данные смешиваются с текущими
Уровень уверенности	Средний — web.archive.org подтверждает наличие артефактов; неясна актуальность для текущего контура
Приоритет	Средний — требует периодического аудита архивных страниц
Возможное защитное действие	Аудит архивных страниц; HTTP 410 (Gone) для устаревших эндпоинтов; запрос на удаление неактуальных страниц из archive.org
Ограничения вывода	Некоторые исторические данные могут быть релевантны для аудита compliance; полный контроль над архивами невозможен

Форма 12. Карточка предупреждения 4

Поле	Содержание
Название сигнала	SIG-4: Единый OAuth-контур — correlation рисков
Описание	OAuth-контур oauth.yandex.com является единой точкой аутентификации для всей экосистемы Яндекса
Источник	oauth.yandex.com (OAuth 2.0 PKCE S256); x-yandex-req-id (HTTP-заголовков)
Что изменилось	OAuth-контур остаётся стабильным, но каждая интеграция с OAuth повышает наблюдаемость пользовательских сессий и позволяет коррелировать действия across сервисов
Почему это важно	Единый OAuth позволяет внешнему наблюдателю: определить все сервисы, использующие OAuth; через x-yandex-req-id коррелировать действия пользователя; обнаружить паттерны авторизации
Уровень уверенности	Высокий — OAuth-спес подтверждён прямым анализом спецификации; DevTools подтверждает x-yandex-req-id
Приоритет	Средний — OAuth архитектурно оправдан, но требует мониторинга
Возможное защитное действие	Ограничение списка сторонних клиентов в

	OAuth-настройках; мониторинг аномальных авторизаций; ограничение информации в x-yandex-req-id
Ограничения вывода	Единый OAuth — стандартизированный паттерн для SaaS-платформ; полностью устранить correlation невозможно

5. Мониторинговая сводка и визуализация

Форма 13. Распределение сигналов по категориям

Категория	Количество сигналов	Приоритеты
Доменные следы	SIG-3	Средний
OSS-следы	SIG-1	Высокий
Кадровые следы	SIG-2	Высокий
Сервисные следы (OAuth, CDN)	SIG-4, SIG-5	Средний
Исторические следы	SIG-6	Средний
Контактные следы (почта)	SIG-7	Средний

Форма 14. Распределение по приоритетам

Приоритет	Количество	Сигналы
Высокий	2	SIG-1 (OSS), SIG-2 (вакансии)
Средний	5	SIG-3 (домены), SIG-4 (OAuth), SIG-5 (CDN), SIG-6 (архивы), SIG-7 (почта)
Низкий	0	—

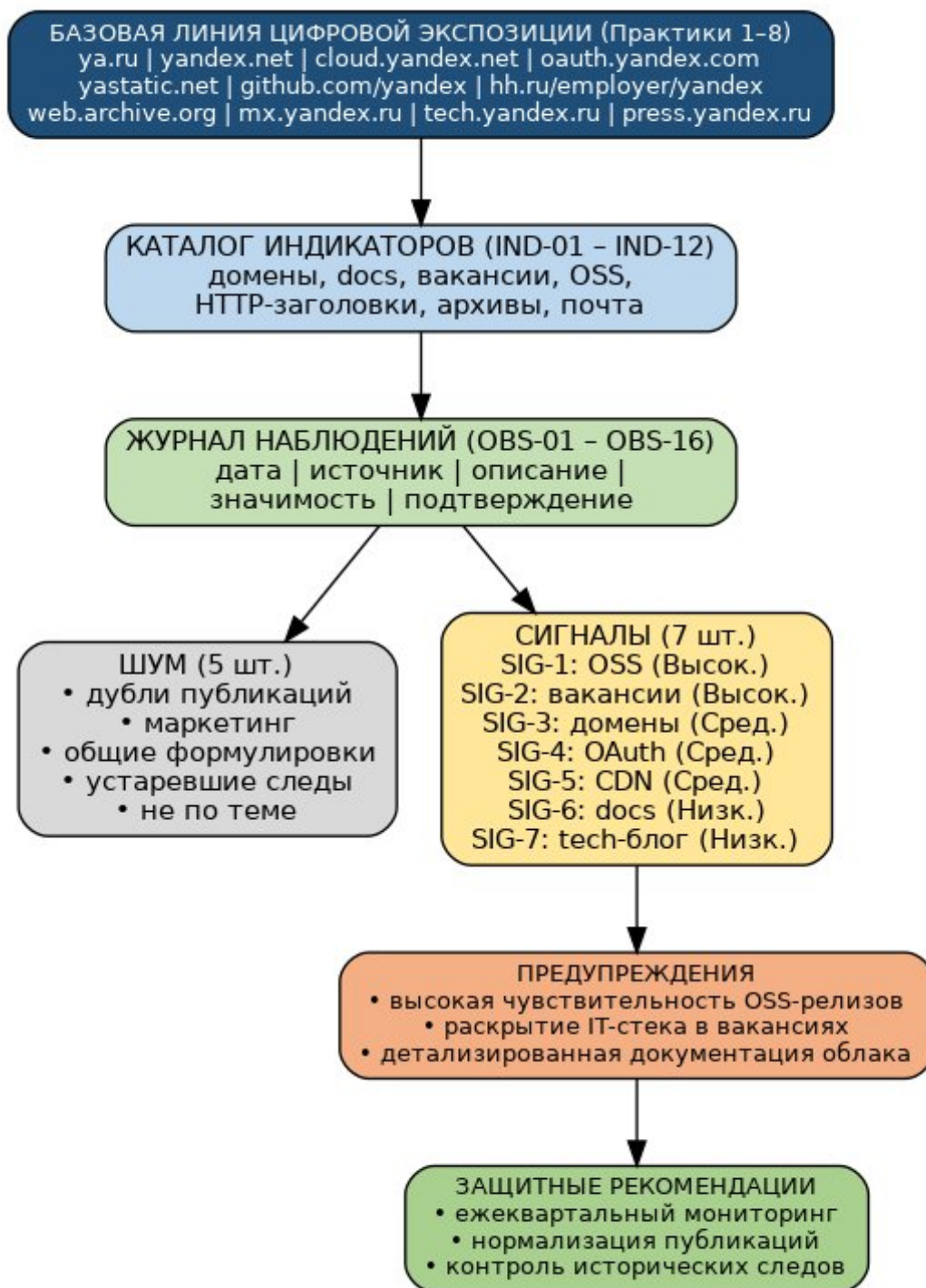
Форма 15. Распределение по источникам

Класс источника	Количество наблюдений	Значимые сигналы
OSS-репозитории	2	SIG-1
Вакансии	1	SIG-2
Доменная инфраструктура	2	SIG-3, SIG-5
OAuth / сервисные заголовки	1	SIG-4
Веб-архив	1	SIG-6
Почтовые DNS	1	SIG-7

Форма 16. Распределение по уровням уверенности

Уровень уверенности	Количество сигналов	Сигналы
Высокий	3	SIG-1, SIG-3, SIG-4
Средний	4	SIG-2, SIG-5, SIG-6, SIG-7
Низкий	0	—

Форма 17. Визуализация — схема мониторинговой модели



6. Защитные рекомендации

Форма 18. Защитные рекомендации

№	Рекомендация	Связь с сигналами	Приоритет
R1	Провести аудит OSS-репозиторий и удалить примеры с внутренними API-эндпоинтами, секретными конфигурациями, CI/CD-паттернами. Внедрить pre-commit хуки для проверки на чувствительные паттерны.	SIG-1 (OSS)	Высокий
R2	Пересмотреть шаблон публикации вакансий: использовать обобщённые формулировки вместо конкретных версий библиотек и кодовых названий проектов.	SIG-2 (вакансии)	Высокий
R3	Провести аудит архивных страниц и установить HTTP 410 (Gone) для устаревших эндпоинтов. Запросить удаление неактуальных страниц из web.archive.org.	SIG-6 (архивы)	Средний
R4	Ограничить список разрешённых сторонних клиентов в OAuth-настройках; внедрить мониторинг аномальных авторизаций; ограничить информацию в x-yandex-req-id.	SIG-4 (OAuth)	Средний
R5	Разделить CDN-пулы	SIG-5 (CDN)	Низкий

	для критических и некритических сервисов; ограничить кросс-доменные CSP-заголовки.		
R6	Внедрить DMARC с политикой p=reject; ежегодно аудировать DNS-записи (SPF, DKIM) на соответствие принципам минимальной экспозиции.	SIG-7 (почта)	Средний
R7	Установить регулярную (ежеквартальную) проверку открытых публикаций на наличие скриншотов с незакрытыми внутренними интерфейсами.	SIG-2 (вакансии)	Средний

7. Ограничения исследования

Форма 19. Ограничения мониторинговой модели

Ограничение	Как влияет на выводы	Как компенсировалось
Мониторинг построен на агрегированных данных практик 1–8 (снимок на май 2026)	Нельзя отследить реальную динамику — изменения выведены из статического среза	Изменения формализованы как гипотетические сценарии мониторинга
Только пассивные методы OSINT	Не обнаружены непубличные изменения (внутренние сервисы, CI/CD, мониторинг)	Указан уровень уверенности; категоричные выводы избегаются
Часть данных историческая (web.archive.org, HTTP 404)	Неясно, какие артефакты актуальны для текущего контура	Исторические следы выделены в отдельную категорию (IND-09, SIG-6)
Некоторые связи подтверждены косвенно (DNS-паттерн, CSP)	Корреляция по индикаторам может быть неточной	Уровень уверенности снижен до «Среднего» для косвенных связей
Не оценивается экспозиция мобильных приложений	Мобильные SDK могут раскрывать дополнительные сведения	Ограничение явно указано

Не анализирована динамика вакансий во времени	Вакансии могли измениться после сбора данных	Указан период; вакансии рассматриваются как динамичный источник
---	--	---

8. Контрольные вопросы для мини-защиты

Вопрос 1: Что в вашей работе является базовой линией?

Ответ: Базовая линия — это исходное зафиксированное состояние цифровой экспозиции объекта (агрегация данных практик 1–8 на момент май 2026): домены (ya.ru, yandex.net), сервисные контуры (cloud.yandex.net, oauth.yandex.com, yastatic.net), OSS-экосистема (github.com/yandex, ydb.tech, ytsaurus.tech), документация, вакансии (hh.ru), почтовая инфраструктура (mx.yandex.ru), исторические следы (dzen.yandex.net, career.yandex.ru). Все наблюдения сравниваются с этой базовой линией.

Вопрос 2: Какие индикаторы вы выбрали и почему?

Ответ: 12 индикаторов (IND-01–IND-12): появление нового домена (IND-01), изменение DNS (IND-02), новые TLS-сертификаты (IND-03), новая docs (IND-04), изменение вакансий (IND-05), новая OSS-docs (IND-06), изменение HTTP-заголовков (IND-07), новые публикации (IND-08), архивные изменения (IND-09), изменение почтовых DNS (IND-10), внешние верификации (IND-11), визуальные изменения (IND-12). Выбраны по критерию способности указывать на изменение наблюдаемости цифрового контура.

Вопрос 3: Какие источники оказались наиболее информативными?

Ответ: OSS-репозитории (ydb.tech, ytsaurus.tech, github.com/yandex с 65K+ звёзд) и вакансии (hh.ru с 600+ developer) — наиболее информативны, так как содержат максимальную детализацию внутренней архитектуры и технологического стека. Доменные и DNS-записи — наиболее достоверны (высокое доверие).

Вопрос 4: Какие наблюдения вы отнесли к шуму?

Ответ: OBS-10 (career.yandex.ru HTTP 404 — переезд, не новое изменение), OBS-09 (dzen.yandex.net — устаревший след, более не актуален), OBS-13 (google-site-verification — стандартная интеграция), OBS-12 (Яндекс.Субботник — событийный контент, не меняет экспозицию), OBS-15 (дубли press.yandex.ru/Habr). Обоснование: устаревшие, маркетинговые, стандартные, не относящиеся к экспозиции.

Вопрос 5: Какие сигналы получили высокий приоритет и почему?

Ответ: SIG-1 (OSS-экосистема) и SIG-2 (вакансии). Оба имеют: (1) высокую значимость для экспозиции; (2) высокую полезность для внешнего наблюдателя; (3) достаточно подтверждены (SIG-1 — HTTP 200 + docs + github; SIG-2 — hh.ru + tech.yandex.ru/career). OSS: максимальная детализация архитектуры; вакансии: 600+ позиций с техническими деталями.

Вопрос 6: Как вы определяли уровень уверенности?

Ответ: Три уровня: (1) Высокий — несколько независимых подтверждений (WHOIS + DNS + HTTP; OAuth-spec + DevTools); (2) Средний — один надёжный источник или косвенная корреляция (HR ≠ инфраструктура; DNS-паттерн ≠ доказательство); (3) Низкий — слабое или одиночное наблюдение. Для каждого сигнала уровень указан с обоснованием.

Вопрос 7: Какие защитные рекомендации прямо следуют из ваших наблюдений?

Ответ: R1–R7 (форма 18). Наиболее значимые: R1 (аудит OSS — высокий приоритет), R2 (обобщение вакансий — высокий приоритет), R3 (аудит архивов — средний приоритет), R4 (OAuth-мониторинг — средний приоритет). Каждая рекомендация связана с конкретным сигналом.

Вопрос 8: Какие ограничения имеет предложенная модель мониторинга?

Ответ: 6 ограничений (форма 19): снимок на один момент времени (май 2026), только пассивные методы, исторические данные, косвенные связи, мобильные приложения не оценены, отсутствие динамики вакансий. Все ограничения учтены при интерпретации результатов.

Вопрос 9: Как можно развить эту работу в долгосрочный мониторинговый процесс?

Ответ: Автоматизировать мониторинг: скрипт проверки DNS/TLS ежедневно, RSS-мониторинг вакансий еженедельно, cron-проверка web.archive.org, API github.com/yandex для новых репозиторий. Визуализация в дашборде с алертами при превышении порогов. Интеграция с SIEM-системой для корреляции с внутренними данными.

Вопрос 10: Почему изменение не равно уязвимости?

Ответ: Изменение — наблюдаемый факт (новый домен, обновлённая вакансия). Уязвимость — возможность эксплуатации. Изменение становится значимым только в совокупности: одна вакансия не опасна, но 600+ формируют технологическую карту. Оценка — контекстуальная, а не категоричная. Рекомендации — защитные, не атакующие.